

HANDOUT PESERTA DIKLAT

Modul 4.4: Perancangan Sistem Keamanan & Keterlacakan Terintegrasi

Program Penguatan Kompetensi Tata Kelola Kearsipan
Level 4 (Mastery) – Manajemen Atas

PT PLN (Persero) | Pusat Pendidikan dan Pelatihan

Daftar Isi

1	Kontrol Akses Berbasis Peran (RBAC) Terintegrasi	3
1.1	Integrasi Konseptual dengan Sistem Kepegawaian	3
1.2	Matriks Role $\times$ Klasifikasi Arsip PLN	3
2	Mekanisme Audit Trail Otomatis & Keterlacakan	5
2.1	Kerangka 4W & Field Metadata Wajib	5
2.2	Prinsip Immutable & Trust-Chain	5
3	Kebijakan Keamanan Terintegrasi dengan ISMS	7
3.1	Integrasi dengan ISO/IEC 27001:2022	7
3.2	Tiga Prinsip Fundamental Kebijakan	7
4	Sistem Backup & Disaster Recovery Terintegrasi	9
4.1	Strategi Backup 3-2-1 untuk Arsip PLN	9
4.2	Penetapan RTO & RPO Berbasis Criticality	9
4.3	Business Continuity Plan (BCP) Kearsipan	9
5	Validasi, Portofolio & Executive Tollgate	11
5.1	Ringkasan Kriteria Penilaian	11
5.2	Executive Tollgate Verifikasi	11

Pendahuluan

Modul 4.4 merupakan mata pelajaran penutup dalam Level 4 (Mastery) yang berfokus pada perancangan tata kelola keamanan, integritas, dan keterlacakan arsip digital. Sasaran utamanya adalah membekali Manajemen Atas PLN dengan kemampuan merancang sistem keamanan yang terintegrasi penuh dengan kebijakan korporasi, regulasi nasional, dan prinsip GCG BUMN.

Sasaran & Prasyarat Peserta

- **Target:** Manajemen Atas (Unit Kearsipan, IT Governance, GCG, Risk Management)
- **Prasyarat:** Lulus Modul 4.3, memahami klasifikasi arsip dasar, familiar dengan SAP/SSO organisasi
- **Output:** 4 dokumen portofolio kebijakan/prosedur siap validasi manajemen

Batas Cakupan (Anti-Overlap)

Fokus Modul 4.4: Kebijakan kontrol akses, mekanisme audit trail, integrasi ISMS, strategi backup/DR.

Bukan Ranah 4.4: Desain arsitektur teknis/API (4.2), optimasi alur kerja bisnis (4.3), evaluasi infrastruktur eksisting (4.1).

Bab 1

Kontrol Akses Berbasis Peran (RBAC) Terintegrasi

(Kriteria Penilaian 4.4.1)

RBAC bukan sekadar matriks izin, melainkan **kerangka tata kelola** yang menghubungkan identitas kepegawaian dengan hak akses arsip secara otomatis. Prinsip dasarnya adalah *least privilege* dan *segregation of duties*.

1.1 Integrasi Konseptual dengan Sistem Kepegawaian

Hak akses tidak diberikan kepada individu, melainkan kepada **peran (role)** yang terikat pada:

- **Jabatan/Fungsi:** Otomatis provisioning saat mutasi/promosi, de-provisioning saat pensiun/resign.
- **Single Sign-On (SSO):** Autentikasi terpusat mengurangi risiko password sharing dan celah akses manual.
- **Lifecycle Management:** Review hak akses berkala (minimal tahunan) untuk memastikan relevansi dengan tugas aktual.

1.2 Matriks Role × Klasifikasi Arsip PLN

Skema akses ditentukan oleh perpotongan peran organisasi dan tingkat sensitivitas arsip:

Tabel 1.1: Matriks RBAC Standar untuk Arsip Digital PLN

Peran (Role)	Publik/Internal	Terbatas	Rahasia	Vital
Inisiator/Staf	C, R	R	–	–
Validator/Manajer Unit	C, R, U	C, R, U	R	R
Auditor Internal	R	R, E	R, E	R, E
Manajemen Atas	R	R, U	R, U, A	R, U, A
Sistem/Service Account	Auto-capture, Indexing	Auto-classify	–	–

Keterangan: C=Create, R=Read, U=Update, A=Approve, E=Export/Review

[WORKSHOP] Aktivitas Workshop (30 Menit)

1. Identifikasi 3 peran kunci di unit Anda yang bersentuhan dengan arsip.
2. Tentukan hak akses (CRU) untuk 3 klasifikasi arsip operasional.
3. Rancang mekanisme review revokasi akses tahunan.

Output Portofolio

[DONE] **Portofolio 1:** *Matriks RBAC Terintegrasi + Prosedur Provisioning/Deprovisioning*. Dinilai berdasarkan kejelasan role, prinsip least privilege, dan keterkaitan dengan sistem kepegawaian.

Bab 2

Mekanisme Audit Trail Otomatis & Keterlacakan

(Kriteria Penilaian 4.4.2)

Audit trail adalah **jejak digital immutable** yang merekam setiap interaksi dengan arsip. Tanpa audit trail yang terdesain sejak awal, arsip digital kehilangan kekuatan hukum dan akuntabilitasnya.

2.1 Kerangka 4W & Field Metadata Wajib

Setiap log audit wajib mencatat: **WHO** (ID+Role), **WHAT** (aksi/view/edit/approve), **WHEN** (timestamp ISO 8601 presisi tinggi), **WHERE** (sumber/IP/lokasi sistem).

Untuk memenuhi standar PP 71/2019 & Perka ANRI 6/2021, terapkan **14 Field Metadata Audit**:

Tabel 2.1: 14 Field Metadata Audit Trail (12 Wajib + 2 Semi-Mandatory)

Kode	Nama Field	Sumber Data	Status
DOC_ID	ID Dokumen Unik	Sistem Nomor	[OK] Wajib
TIMESTAMP	Waktu Aksi (ISO 8601)	System Clock	[OK] Wajib
HASH_SHA256	Nilai Hash Integritas	Cryptographic Module	[OK] Wajib
CREATOR_ROLE	Peran Pengguna	IAM/SSO	[OK] Wajib
AUDIT_LOG_ID	ID Log Immutable	SIEM/Audit Engine	[OK] Wajib
CLASSIFICATION	Tingkat Keamanan	Policy Engine	[OK] Wajib
RETENTION_RULE	Aturan Retensi	Schedule DB	[OK] Wajib
ASSET_ID	Referensi Aset PLN	SAP-PM/AMS	[OK] Wajib
CONTRACT_REF	Referensi Kontrak	E-Proc/Legal	[OK] Wajib
LOCATION_GIS	Lokasi Operasional	Master Data	[OK] Wajib
INTEGRITY_HASH	Verifikasi Perubahan	Hash Module	[OK] Wajib
AUDIT_TRAIL_REF	Log Terkait	Chain Log	[OK] Wajib
CONTENT <i>DESC</i>	Ringkasan Isi	NLP/Input	[WARN] Semi
SEARCH <i>TAGS</i>	Kata Kunci Terkontrol	Thesaurus	[WARN] Semi

2.2 Prinsip Immutable & Trust-Chain

- Log audit disimpan terpisah dari sistem produksi dengan kebijakan *Write-Once-Read-Many* (WORM). - Hash SHA-256 menjamin deteksi perubahan 1 byte seketika. - Setiap

approval wajib menggunakan Tanda Tangan Elektronik Tersertifikasi (TTE) untuk kekuatan hukum *non-repudiation*.

[WORKSHOP] Aktivitas Workshop (30 Menit)

1. Gambar alur audit trail dari penciptaan → validasi → penyimpanan.
2. Lengkapi template 14 field untuk 1 jenis arsip kritis unit Anda.
3. Tentukan mekanisme eskalasi jika hash integrity gagal verifikasi.

Output Portofolio

[DONE] **Portofolio 2:** *Diagram Alur Audit Trail + Template Log 14 Field*. Di-
nilai berdasarkan kelengkapan 4W, kejelasan immutability, dan keselarasan dengan
regulasi PSTE.

Bab 3

Kebijakan Keamanan Terintegrasi dengan ISMS

(Kriteria Penilaian 4.4.3)

Kebijakan keamanan arsip tidak boleh berdiri sendiri. Ia harus menjadi bagian tak terpisahkan dari **Sistem Manajemen Keamanan Informasi (ISMS)** organisasi dan mendukung prinsip GCG BUMN (TARAK).

3.1 Integrasi dengan ISO/IEC 27001:2022

Arsip digital dikategorikan sebagai **Aset Informasi Kritis**. Integrasi dilakukan melalui:

- **A.8 Asset Management:** Inventarisasi, klasifikasi, dan penentuan *owner* arsip.
- **A.5 Information Security Policies:** Penyelarasan kebijakan induk kearsipan dengan kebijakan keamanan informasi korporasi.
- **A.12 Operations Security:** Prosedur operasional backup, monitoring log, dan penanganan insiden kebocoran.

3.2 Tiga Prinsip Fundamental Kebijakan

1. **Least Privilege:** Hak akses minimum yang diperlukan untuk menyelesaikan tugas.
2. **Defense in Depth:** Lapisan pengamanan berlapis (fisik, jaringan, aplikasi, data, kebijakan).
3. **Zero Trust:** Tidak ada akses default. Setiap permintaan diverifikasi secara eksplisit berdasarkan konteks (role, device, lokasi, waktu).

[GCG] Integrasi GCG BUMN (TARAK)

Tabel 3.1: Pemetaan Prinsip GCG ke Kebijakan Keamanan Arsip

Prinsip TARAK	Implementasi dalam Kebijakan Arsip
Transparansi	Audit trail dapat diakses Auditor Internal/Eksternal sesuai kewenangan
Akuntabilitas	RACI digital jelas; setiap aksi terikat identitas
TTE	
Responsibilitas	Kepatuhan PP 71/2019 & Perka ANRI 6/2021 wajib diuji berkala
Independensi	Unit Kearsipan berwenang tolak arsip tidak memenuhi standar metadata
Kewajaran	Akses berbasis need-to-know, tidak diskriminatif, ada mekanisme banding

[WORKSHOP] Aktivitas Workshop (30 Menit)

1. Susun draf klausul kebijakan keamanan arsip (maks. 2 halaman).
2. Petakan minimal 3 kontrol ISO 27001 yang relevan dengan unit Anda.
3. Integrasikan 1 klausul pendukung prinsip TARAK.

Output Portofolio

[DONE] **Portofolio 3:** *Draft Kebijakan Keamanan Arsip Terintegrasi ISMS*. Dini-lai berdasarkan keselarasan ISO 27001, kejelasan prinsip Zero Trust/Least Privilege, dan integrasi GCG BUMN.

Bab 4

Sistem Backup & Disaster Recovery Terintegrasi

(Kriteria Penilaian 4.4.4)

Keamanan arsip tidak lengkap tanpa jaminan ketersediaan pasca-gangguan. Fokus pada level kebijakan: strategi, target pemulihan, dan kesiapan organisasi.

4.1 Strategi Backup 3-2-1 untuk Arsip PLN

- 3 salinan data (produksi + 2 backup)
- 2 media penyimpanan berbeda (misal: NAS lokal + Cloud/Offsite terenkripsi)
- 1 salinan disimpan di lokasi geografis terpisah dari data center utama

Kebijakan wajib mencantumkan jadwal backup otomatis, enkripsi *at-rest/in-transit*, dan verifikasi integritas pasca-backup.

4.2 Penetapan RTO & RPO Berbasis Criticality

4.3 Business Continuity Plan (BCP) Kearsipan

Kebijakan DR harus mencakup:

1. Prosedur fallback digital/manual saat sistem *down* > 4 jam.
2. Prioritas recovery: Vital → Rahasia → Internal.
3. Jadwal uji drill recovery minimal 6 bulan sekali dengan dokumentasi *lesson learned*.
4. Mekanisme komunikasi krisis & eskalasi ke manajemen puncak.

[WORKSHOP] Aktivitas Workshop (30 Menit)

1. Tentukan klasifikasi arsip vital di unit Anda.
2. Tetapkan target RTO/RPO realistis.
3. Rancang jadwal backup & skenario uji drill 6 bulanan.

Output Portofolio

[DONE] **Portofolio 4:** *Matriks RTO/RPO + Rencana Backup & DR*. Dinilai berdasarkan kesesuaian 3-2-1, realisme target RTO/RPO, dan kejelasan prosedur fallback/drill.

Tabel 4.1: Target Pemulihan (RTO/RPO) Berdasarkan Klasifikasi Arsip

Klasifikasi	RTO (Waktu Pemulihan)	RPO (Toleransi Kehilangan Data)	Strategi Pri-oritas
Vital	< 4 jam	< 1 jam	Mirror site aktif, fail-over otomatis
Rahasia	< 12 jam	< 4 jam	Backup harian terenkripsi, restore manual teruji
Internal/Publik	< 24 jam	< 12 jam	Backup mingguan, arsip dingin (cold storage)

Bab 5

Validasi, Portofolio & Executive Tollgate

5.1 Ringkasan Kriteria Penilaian

Tabel 5.1: Peta Kriteria → Portofolio → Bobot Penilaian

Kriteria	Portofolio Wajib	Fokus Penilaian	Bobot
4.4.1 RBAC Terintegrasi	Matriks RBAC + Prosedur Akses	Least privilege, integrasi HR/SSO, review berkala	25%
4.4.2 Audit Trail Otomatis	Alur Audit + Template 14 Field	Immutability, 4W, compliance PSTE/ANRI	25%
4.4.3 Kebijakan ISMS	Draft Kebijakan Keamanan	ISO 27001 alignment, Zero Trust, TARAK GCG	25%
4.4.4 Backup & DR	Matriks RTO/RPO + Rencana DR	3-2-1, target realistis, BCP integration	25%

Kelulusan: Skor portofolio ≥ 70 , post-test ≥ 65 , submit komitmen tindak lanjut.

5.2 Executive Tollgate Verifikasi

Sebelum implementasi, rancangan harus lolos 4 gate:

1. **GATE LEGAL:** Selaras PP 71/2019 & Perka ANRI 6/2021?
2. **GATE INTEGRITY:** Jamin keaslian via Hash + TTE + Audit Immutable?
3. **GATE VALUE:** Mitigasi risiko terkuantifikasi (downtime ↓, temuan audit → 0)?
4. **GATE SCALE:** Infrastruktur & prosedur siap diskalakan jangka panjang?

Jika 1 gate bernilai **No**, lakukan re-design sebelum diajukan ke Komite Tata Kelola.

Daftar Pustaka Terseleksi

1. PP No. 71/2019 tentang PSTE & Perka ANRI No. 6/2021 tentang Keamanan Arsip Elektronik
2. ISO/IEC 27001:2022 & ISO 22301:2019 (Business Continuity)
3. NIST Cybersecurity Framework 2.0 & NIST SP 800-53 (Access Control & Audit)
4. PER-2/MBU/03/2023 tentang Pedoman Tata Kelola & GCG BUMN
5. World Bank RM Roadmap Part 8 (Resources) & Part 9 (Implementation)
6. The National Archives (UK). Security Guidance for Archives & Records (2023)

NOTE

Penutup] Keamanan & keterlacakan bukan hambatan operasional, melainkan **enabler akuntabilitas korporasi**. Rancangan yang Anda susun dalam modul ini menjadi fondasi tata kelola arsip PLN yang tahan audit, patuh regulasi, dan siap mendukung transformasi digital kelas dunia.